

7.15 release Stack 04 — chain signing audit

1. Identity and frozen scope

- Owner: Codex /root, keepkey-vault-v11-agent-2. The claim and master ledger live in the **main firmware worktree** at docs/release/audit-claims/715-04/OWNER.md and docs/release/MASTER-AUDIT-TEMPLATE.md.
- Main master form SHA256 at intake:
fd8669396fcebde1a04e40946b92465f95d8b3e56c03c93bf75424649a967d81.
- Isolated source worktree: /private/tmp/kk715-stack04-audit, branch audit/715-stack04-review.
- Code-bearing PR: [#834](#), release/715-stack-04-chain-signing against release/715-stack-03-recovery. Frozen predecessor 2e008f8527f663107922835dbc8761333b8f073f; intake head 9e6c56c267c6755f55364f2a48073880b4f6f6e4; local repair commit eeee19feb8d1961176b46e7e6e656be1c550c4e8. The final containing report head belongs in the PR body after commit.
- Candidate is an internal release stack unit, not assembled release acceptance. Stack 03 predecessor audit acceptance, host/emulator signing flows, physical OLED/signing checks, exact-head CI, and external code review remain separate gates.
- No dependency pointer changes occur in this adjacent diff. Top-level pins: trezor crypto 8a392f70a5d5575ece3dfb35f115d4a4b27f497c; protocol dd9c85dc747cf965fb0e7bf49615dc9e7568ee65; Python host 49d537ce953b7524599bfc87f56b7a50a51a13a1; QR 6dfbfddad5d9303ed190d1c3cb7bec34b565b6ce8; SecAES 71d356a1141624994cf613bd2d2583892e8e6d5a; code signing keys a6470bd8598e5e9a7bfc38bf139a5e5a616f05ec. The nested Python protocol and Ethereum list pins are dd9c85dc747cf965fb0e7bf49615dc9e7568ee65 and 89a64f717e1690bb31adb3e4c38e23640357333c.

2. Git line inventory and plain-language changes

The original unit is the single commit 9e6c56c267c6755f55364f2a48073880b4f6f6e4. Immutable inventory command: `git show --format= --numstat --no-renames 9e6c56c267c6755f55364f2a48073880b4f6f6e4`. The source repair command is `git show --format= --numstat --no-renames eeee19feb8d1961176b46e7e6e656be1c550c4e8`. Counts overlap in two source files and must not be summed into a net diff.

Path	Original +/–	Repair +/–	Behavior and audit result
docs/firmware/reviews/7.15.0-review-round2-remediation.md	3/3	0/0	Updates historical B1, M13, M14 statuses. Source checks below qualify these claims; this document alone is not verification.
lib/firmware/fsm_msg_mayachain.h	0/8	10/0	Original removed the separate Asset screen; repair restores a complete paged denomination disclosure after the amount/recipient screen, with cancellation aborting signing. Net adjacent diff: 5/3.
lib/firmware/fsm_msg_ton.h	5/2	0/0	Formats the blind-sign byte-count prompt into a 48-byte local buffer before confirmation. It continues to disclose the signed byte count and require the AdvancedMode gate inherited from Stack 03.
lib/firmware/fsm_msg_tron.h	15/8	5/15	Original replaced the complete memo pager with one screen or a byte-count summary. Repair calls <code>confirm_bytes</code> on the exact signed memo bytes. Net adjacent diff: 5/8.
unittests/firmware/CMakeLists.txt	2/1	0/0	Adds existing TRON parser tests to the regular native suite; Bitcoin-only excludes them.

Path	Original +/-	Repair +/ -	Behavior and audit result
unittests/firmware/tron.cpp	0/0	33/0	New long binary memo test approves each prior page, rejects the final page, then approves all pages; confirms no queued responses remain.

The net code-predecessor command is `git diff --numstat 2e008f8527f663107922835dbc8761333b8f073f..eeee19feb8d1961176b46e7e6e656be1c550c4e8`; its six paths and counts are 3/3, 5/3, 5/2, 5/8, 2/1, and 33/0 in the order above. This report source and its PDF are additional documentation paths in the final PR diff; their final identity and counts are recorded in the PR body because a file cannot contain its own final commit hash.

3. Current-source reconciliation and security findings

Finding	Sensitive signed state and observer	Path, assertion, falsification, disposition
S04-1, TRON memo tail hidden	<code>raw_data.data</code> memo bytes originate in the host's <code>TronSignTx.raw_tx</code> , are serialized into the signed transaction, and must be disclosed in full to the person on the device before signing. Applies to regular firmware during TRON signing; Bitcoin-only has no TRON handler. A byte-count summary, truncated line, or hidden binary tail is forbidden.	The original adjacent diff used one unpagged <code>confirm</code> for up to 114 printable bytes and only "Data attached (N bytes)" for binary/long memos. The repair calls <code>confirm_bytes</code> on <code>parsed.memo</code> and <code>parsed.memo_len</code> , which escapes and pages all bytes and requires final-page hold. <code>Tron.LongBinaryMemoRequiresApprovalOfEveryPage</code> executes both final-page rejection and full approval with an embedded NUL and a distinct final byte; all 24 TRON tests pass. The negative test attempts to withhold the final page. Fixed in local code; integration and external review pending.
S04-2, MayaChain asset removed	<code>send.denom/default cacao</code> is the asset serialized into the signing JSON; a person on the device must see it. Applies to regular firmware during MayaChain send signing. The single amount/recipient layout can clip a long denomination; a clipped tail is forbidden.	Original adjacent diff deleted the independent Asset confirmation. The repair calls <code>confirm_bytes("Asset", coin_denom, strlen(coin_denom))</code> after amount/recipient approval and aborts on refusal. The prior 68-character valid-denomination serialization test and 11 MayaChain tests pass; full handler cancellation is source-traced, not independently exercised. Fixed in local code; targeted handler transport test and external review pending.

TON's 48-byte buffer fits the literal prompt and a 32-bit unsigned decimal byte count (at most 37 bytes plus NUL), so this formatting change does not truncate the value. The blind-only policy and `AdvancedMode` gate are inherited, not introduced by this commit. Historical M13's TRON typed-hash gate and M14's enlarged amount buffer are present in the predecessor; the changed status rows are provenance notes, not new Block 04 implementation. B1's ARM link claim is supported here by the full `MinSizeRel` ARM link; the `trezor` pointer itself did not change in Block 04. The original "M14 fixed" row does not excuse the separate asset-display regression found above.

4. Verification and artifact identity

Build image: `kktech/`

`firmware@sha256:7438e53933d47d53157ed6d96d864cb208597e62dce26235ace09d1063427fa2`. All local checks use source commit `eeee19feb8d1961176b46e7e6e656be1c550c4e8` and the unchanged dependency pins above.

Check	Result	Evidence and limit
Targeted regular native	Pass , 35/35 TRON and MayaChain tests	Pinned Docker emulator build; <code>firmware-unit '--gtest_filter=Tron.:Mayachain.'</code> . Includes new final-page refusal test. No physical OLED observation.
Full regular native	Pass , firmware 433/433, board 19/19, crypto 18/18, Zcash crypto 72/72	Pinned Docker build; each binary run from a fresh temporary emulator working directory. A preliminary <code>make xunit</code> from a reused persistent directory failed one recovery test because prior emulator flash remained; the same test and all suites pass in fresh directories.
Bitcoin-only native	Pass , firmware 121/121, board 19/19, crypto 18/18	Pinned Docker emulator build with <code>-DKK_BITCOIN_ONLY=ON</code> ; <code>make xunit</code> . TRON and MayaChain tests are intentionally absent in this variant.

Check	Result	Evidence and limit
Full ARM MinSizeRel	Pass , firmware.keepkey.elf linked	Pinned Docker device.cmake, make -j4; local build tree /private/tmp/kk715-stack04-arm. Physical signing and signed-device upgrade remain pending.
Bitcoin-only ARM MinSizeRel	Pass , firmware.keepkey.elf linked	Same command with -DKK_BITCOIN_ONLY=0N; local build tree /private/tmp/kk715-stack04-arm-btc.
Host/emulator signing flows, exact-head CI	Pending	Native tests establish parser, format, pager and build behavior. They do not establish a physical approval workflow. Hosted CI must match final report/code head after push.

The local build tree paths are ephemeral artifacts, not reproducible Git inputs. The final exact-head CI run and downloadable artifact IDs belong in the PR description and main ledger once delivered. No production device was used in this audit.

Local artifact SHA256: regular firmware unit
b63acd7260063a7f869e921ac183cc18288c7aac26f1f897ed810f5108d29864, board unit
3caa34c54909f8da3b7f2aa35af6e4c4b054518970b2c7589a8b2068fdc48cf2, crypto unit
52982883650ff3386430168d0ec915442672e9c75cfc5e194a2277f4ea187fe9, Zcash crypto unit
98983e4b6890b3b07e60cf6c18addb3340cff0c6305614a252cc89acab7c058d, Bitcoin-only firmware unit
993e35ab015117211bb8ca597555aa45150ca755146f2849a68547a73f5fa4cc, regular ARM ELF
37640d6471ea5d3a729574b5047c2fe547ebb9b2917cd9c35def75b43641d867, and Bitcoin-only ARM ELF
4004cbe932df1bfb052159f86d3036766d5ffe52beedce03ab40fe6473880b6d.

5. Render, local preflight and review checkpoint

This Markdown is the source report; the matching PDF is 715-04-review-20260923.pdf. Its three rendered pages were opened and checked for legibility. Live PR base/head check, final adjacent diff inventory, git diff --check, and the main worktree's scripts/release/check-code-review-diff.sh remain final-head preflight steps after the report files are frozen. The source changes are three code/test files on top of the original five-path adjacent diff; both the original and repaired ranges are code-bearing.

Status by gate: implementation **done locally**; targeted verification **passed**; native and ARM integration **passed locally**; adversarial display contract **partial** (TRON pager negative path executed, MayaChain handler path source-traced); external review **not requested**; findings disposition **local fixes pending exact-head validation**; predecessor and release acceptance **pending**. The existing Stack 01 Copilot authorization was for PR #831 only. No Block 04 Copilot request is recorded or implied by this receipt.